

WESTERN REFRIGERATION PVT. LTD.

RBAC Decision Flow

Product: WRL Portal

Version: 1.0 draft

Date: 2026-09-02

Production: <https://wrl-dashboard.vercel.app>

Internal — Handover Documentation

Status: Ready — `RBAC_MATRIX.xlsx` and `ROLES_SNAPSHOT.md` are exported from the live Postgres role tables on each `npm run handover:export`.

Diagram: `03-Technical/diagrams/10-rbac-decision-flow.png` (also in Architecture Diagrams PDF).

Summary

Every portal request is authenticated (Supabase JWT), then authorized in application code — **not** via Postgres RLS. Permissions are defined in `src/lib/auth/rbac-catalog.ts` and stored per role in `app_roles` / `app_role_permissions`.

Step-by-step (API and page loads)

1. Authenticate

- Browser sends session cookie (or Bearer token for cron/relay).
- `server-user.ts` verifies JWT with Supabase GoTrue.
- Invalid or expired → **401** or redirect to `/login`.

2. Load profile and permissions

- Load `app_users` row: role, `office_ids`, expanded permission list from `app_role_permissions`.
- Portal soft-session TTL checked (cookie lifetime).
- Expired → **401**.

3. Office scope

Condition	Data scope
<code>view_all_offices</code> capability, legacy HOD role, or empty <code>office_ids</code>	All branches (national)
Non-empty <code>office_ids</code>	Assigned branches only

Office scope is applied as SQL `WHERE` filters on read-model queries — not a separate RLS layer.

4. Page / route permission

- UI routes: `canAccessPath()` / `canAccessPage(pageId)` against RBAC catalog.
- API routes: `resolveApiAccess()` , `requirePageAccess()` , Or `canAccessPage()` in module handlers.
- No matching permission → **403** (or **404** to hide existence of admin routes).

5. MIS tab permission (MIS Reports only)

- Page `mis_reports` grants access to `/report` .
- Each tab (Summary, Register, Accounts, BD-MIS, etc.) has a separate `tab_mis_*` permission.
- Tab hidden if role lacks permission **or** feature flag off (e.g. BD-MIS when flag disabled).

6. Capability gates (orthogonal to pages)

Capability	Grants
<code>super_admin</code>	Activity Log (<code>/admin/security-audit</code>), VPS Cron tab in Mail & Alerts, Call Register CRM sync → yesterday
<code>manage_users</code>	User Management, Read-model sync status, Service call activity; also opens Mail & Alerts hub (OR-gate)
<code>manage_roles</code>	Roles & Access UI; also opens Mail & Alerts hub (OR-gate)
<code>mis_email_send</code>	Profile email prefs, digest recipient eligibility
<code>mis_client_import_upload</code> / <code>_delete</code>	Client import upload/delete
<code>view_all_offices</code>	National scope (see step 3)

7. Per-resource checks

- **Call drawer** (`/api/calls/[id]`): **Call Register tab** (`tab_mis_register`) + `canAccessOffice(nofficeid)` for the call's branch.
- **Comments / flags write**: same office check as drawer.
- **Mail & Alerts hub** (`/admin/mis-email-settings`): `page_mis_email_settings` **or** `manage_users` / `manage_roles` / `view_all_offices` / legacy mail page permissions (OR-gate in `canAccessPage`).
- **Athena reconciliation** permission also grants access to cancelled-calls report path (alias in catalog).

Validate with stakeholders (optional)

The Excel **RoleMatrix** and **ROLES_SNAPSHOT.md** reflect **current production** roles. Confirm if needed:

1. Each role has the correct **pages** and **MIS tabs** — change in `/admin/roles` if not, then re-export.
 2. Which users need **national scope** vs branch-only (`view_all_offices` / `office_ids`).
 3. Who should have **MIS email** (`mis_email_send`) vs view-only report access.
 4. **Super admin** — restrict to IT/ops; not for HOD or branch managers.
-

Related

- Permission catalog: `src/lib/auth/rbac-catalog.ts`
- Roles UI: `/admin/roles`
- Migration SQL for tab aliases: `scripts/rbac/migrate-tab-permission-aliases.sql`
- Full architecture: `03-Technical/ARCHITECTURE.md` §10